SUSHANT POUDEL

SOFTWARE ENGINEER · AI ENGINEER · SECURITY ANALYST

Bhaktapur, Nepal · sushant.poudel2028@gmail.com
github.com/sushant-me · linkedin.com/in/sushant-poudel2028 · sushantpoudel2028.com.np
ORCID 0009-0008-7732-3269 · HackingHub: nofear976

PROFILE

Computer engineer with two years of full-time production experience and a public record in AI systems and security research. At Atmos SoftTech I designed and shipped machine-learning systems, full-stack platforms and offline-first autonomous agent pipelines; at Avatar Tech Solutions I led the web and mobile build and ran IT operations for 30+ workstations; three 2026 AI internships (Next AI, Eminence Ways, Nobel Learning) sit alongside that production work. My recent work is on the security of the agents I used to build: a published ICICSET 2026 paper on whether a small local model can enforce policy for an agent that executes actions, a security patch merged into google/go-github and credited in its AUTHORS file and release notes, five memory-safety issues in google/s2geometry, and four published GitHub security advisories for vulnerabilities in my own tooling. Stands 7th on the HackingHub all-time global leaderboard (210 flags, 21,785 XP) and finished 2nd of 8 teams in the NullOrigin CTF 2026 Grand Finale. Final-year Computer Engineering at Nepal Engineering College.

Open to: software engineering, AI engineering and security analysis roles — remote or Kathmandu-based.

CORE COMPETENCIES

SOFTWARE ENGINEERING

Languages: Python, Go, Java, C/C++, TypeScript/JavaScript, SQL, Dart

Web & mobile: React, Next.js, Node.js/MERN, NestJS, Redux, Flutter

Data & auth: REST APIs, PostgreSQL, MongoDB, Supabase, JWT, RBAC

Delivery: Docker, Kubernetes, GitHub Actions, Git, Linux, release automation

Quality: PyTest, Jest, Cypress, Selenium, Postman, TDD/BDD, coverage gates

AI ENGINEERING

Frameworks: PyTorch, TensorFlow/Keras, scikit-learn, NumPy, pandas

LLM systems: fine-tuning, quantized local inference (GGUF/llama.cpp), RAG, LangChain, tool-calling agents, MCP

Evaluation: adversarial and policy evaluation, chain-of-thought verification, trajectory grading, reproducibility harnesses

Modelling: transformers, state-space models (Mamba/S6) from scratch, LSTM, causal inference (do-calculus)

SECURITY ANALYSIS

Research: memory safety (ASan/UBSan/GDB), fuzzing and harness engineering (libFuzzer, OSS-Fuzz), static analysis (CodeQL, Semgrep)

AI/agent security: prompt injection, tool-boundary abuse, MCP supply chain, fail-open authorization

Disclosure: HackerOne triage workflow, CVE/GHSA advisory authoring, coordinated disclosure, threat modelling

Operations: Linux, TCP/IP, DNS, TLS, log and packet triage; CTF (web, pwn, forensics, crypto, OSINT)

EXPERIENCE

Software Developer — Arvion

Remote, part-time *June 2026 – present*

- Application and web development for Arvion's products: building and maintaining features across the mobile application and the web platform, end to end.
- Remote delivery in a distributed team, held alongside independent security research; retained after a three-month trial period.

AI Engineering Internships — 2026

- **Next A.I Pvt. Ltd. (Next AI), Durbarmarg, Kathmandu — Artificial Intelligence Intern** (April–August 2026, on-site). Built a voice-driven application end to end, combining software engineering with speech recognition and applied AI.
- **Eminence Ways, Kathmandu — Artificial Intelligence Intern (Machine Learning)** (May–August 2026, on-site). Applied AI and machine-learning concepts to practical prototypes, turning emerging developments in the field into working implementations.
- **Nobel Learning PBC, remote (Gaithersburg, Maryland) — Fundamentals Program Intern** (December 2025–August 2026). Completed the 90-hour International Learner-to-Leader programme — web design, pitching and presentation — and coached peers through the material.

Technical Lead & Software Developer — Avatar Tech Solutions Pvt. Ltd.

Kathmandu, Nepal *December 2025 – June 2026*

- Technical lead for the company's corporate web ecosystem and a responsive mobile application: architecture, implementation and deployment.
- Ran enterprise IT and hardware operations across 30+ workstations — setup, network configuration and zero-downtime maintenance.
- Built an automated inventory-management system mapping hardware serial numbers to generated reports, removing manual record-keeping from the process.
- Produced the company's digital content and marketing assets, measurably increasing reach and engagement.

AI Engineer — Atmos SoftTech Pvt. Ltd.

Birgunj, Parsa, Nepal · *full-time, 2 years* *March 2024 – March 2026*

- Designed, developed and deployed AI/ML systems in production, owning features end to end from data preparation and model evaluation through deployment and monitoring.
- Built and maintained full-stack web applications — front-end interfaces, back-end services, database design, authentication and release automation — for company and client products.
- Engineered autonomous agent systems: tool-calling pipelines, multi-step task orchestration, retrieval over private data, and offline-first inference where sending data to a cloud API was not acceptable.
- Worked directly with cross-functional teams to turn business requirements into shipped, reliable software; conduct, performance and professionalism rated "highly satisfactory" in the CEO-signed experience letter (Md. Samsad Ali, available on request).

SECURITY & VULNERABILITY RESEARCH

Competitive and research record (handle nofear976)

- **3CX, report #4023713.** Unauthenticated RCE as root on 3CX SBC via a plaintext HTTP apt-key fetch — independently developed, closed as a duplicate of the earlier, bountied #3981550. Recorded as a duplicate, not a first discovery.
- Two further reports were submitted (Elastic, Circle); one was closed without action (Kong — a script-sandbox escape through `eval()` in Insomnia Desktop). Stated limit: the report pages are not publicly disclosed; no CVE and no bounty amount is claimed.

Merged and reviewed upstream work

84 pull requests merged and 33 still open in total as of 13 November 2026. The security-relevant ones:

- **google/go-github (#4556).** Authored and merged: a release-asset upload whose URL pointed at a host other than the configured upload host is refused rather than sent with the client's credentials. The maintainer replaced it the next day with the broader #4564 — "credentials are sent only to configured origins" — which is what master implements today and whose own commit history includes "Address feedback from sushant-me". Credited in the project's AUTHORS file via #4579 and named in the v93.0.0 release notes.
- **google/s2geometry.** Five open memory-safety issues, each with a standalone reproducer: a NULL dereference on the documented traversal path (#674), an out-of-bounds read from an unchecked shape id (#676), a 16 GiB allocation from a 117-byte input (#677), a heap-buffer-overflow in `EncodedS2LaxPolygonShape::edge` (#678), and a 2.4 GiB allocation from a 28-byte input (#679). Two hardening pull requests (#681, #682) are open. The maintainer considers the decoder documented for trusted input — a disagreement about threat model, not about whether the reads are out of bounds.
- **Google ADK — MCP tool shadowing.** A server-supplied MCP tool could occupy a framework-reserved tool name and bypass the duplicate-name guard. The adk-python fix was merged via Copybara on 2 October 2026 (#7145) and adk-go #1606 is open, alongside two further merged adk-go pull requests (#1679 re-enabled a test that had never executed; #1711 corrected doc comments). On the Java side the fix pull request (#1515) was closed by the maintainer in favour of keeping the in-model collision behaviour consistent across the ADK frameworks, and the tracking issue (#1513) was closed a week later.
- **google/libphonenumber (#4079, open).** The OSS-Fuzz as-you-type-formatter harness never generated a valid region or digit, so the published report shows 0.00% line coverage. A local rebuild of the same target measured 23.50% before the proposed fix and 93.05% after.
- **Other upstream reports.** google/osv-scanner #3120 — `nameIsRegex` overrides are anchored per branch, so a top-level alternation silently drops packages from a scan. libpng #935 — `png_set_quantize` allocates a 256-entry palette but copies `num_palette` entries into it; AddressSanitizer confirms a 900-byte write past a 768-byte region, caller-triggered and not reachable from crafted PNG bytes. google/gson #3121 — reject unpaired surrogates in `JsonWriter` STRICT mode. Three OpenTelemetry Go pull requests are open with EasyCLA passing.
- **Trail of Bits.** Two merged pull requests in `trailofbits/skills` (#346 pins the devcontainer toolchain; #347 de-duplicates SessionStart environment exports) and `trailofbits/it-depends` #254 (tests for the HTML graph renderer); detection rules for agentic GitHub Actions pipelines are in the open #311.
- **sisaku-security/sisakulint.** An audit of six AI-action rules found defects in five. The maintainer rebuilt both revisions of a rule and reproduced the finding before accepting it as real, and filed three tracked issues from the audit (#646–#648); the rule pull request itself (#644) was closed for review capacity, not for being wrong.
- **elementalsouls/Claude-BugHunter (#81, merged).** 22 of its 58 `hunt-*` skills had no routing entry and could never be selected; completed the class, technique and probe maps, and added a coverage check for unreachable skills.

Published security advisories

- Four GitHub Security Advisories for vulnerabilities found and fixed in my own security tooling: a newline that stepped around a glob deny rule in policygate (GHSA-qwvv-fcmm-r3j2, high); unbounded reads that let a hostile MCP server kill mcp-nameguard (GHSA-wcqw-86xv-w95q); a masker in agentbound that hid the findings the scanner exists to report (GHSA-mffv-hhg5-mm33); and invisible-character coverage gaps in mcpaudit (GHSA-62f4-h552-54wc). Each ships a reproduction and a regression test; CVE identifiers requested from GitHub's CNA.

Security tooling released

- **agentbound** — static detector for AI-agent tool-boundary bugs: ten rules across Python, TypeScript and YAML for tool shadowing, reserved-name collisions, last-wins tool dictionaries and fail-open confirmation gates.

- **mcpaudit** — audits an MCP server's tool declarations before you connect — reserved-name collisions, instruction-shaped text, invisible Unicode with the tag-block payload decoded, destructive tools declaring `readOnlyHint` — then pins them so a description edited after approval is a reported diff.
- **policygate** — a fail-closed policy gate for agent tool calls: a model may deny or escalate and can never authorise an uncovered action, an unparseable evaluator falls through to a refusal, and every decision goes to a hash-chained audit log.
- **mcp-nameguard**, **trajectorycheck**, **toolgate** (Rust) — reserved-name checking against framework primitives; trajectory-level evaluation grading tool calls, arguments and side effects with a deliberately broken agent as control; a Rust port of the declaration audit.
- **tool-boundary-corpus** — 23 labelled agent tool-boundary cases and a detector-agnostic harness that scores precision and recall. It caught a real false positive in agentbound, which was fixed (precision 0.750 → 1.000) rather than deleted from the corpus.

Platforms and competitions

- **HackingHub** — 7th on the all-time global leaderboard, on 210 flags and 21,785 XP (1 gold, 4 silver, 3 bronze), verifiable from the public leaderboard API. The Q3 2026 period closed with the account at the top of that period's board (177 flags, 18,125 XP); the per-period board has since rolled to Q4 and is no longer served.
- **HackTheBox** — level 81, rank Prodigy (handle nofear976).
- **NullOrigin CTF 2026** (international, 24-hour) — finished **2nd of 8 teams** in the Grand Finale with team roamers: 16,850 points, 40 of 42 challenges solved (final standings: 1st Jokers 17,600, 2nd roamers 16,850). Grand Finale certificate ID NO-2026-GF-229CF4, verifiable at creds.cyberhx.com.

Sources for every security claim above: github.com/sushant-me (merged work), sushant-me/reputation (each claim with its source, re-checked weekly by a script), and app.hackinghub.io/p/nofear976.

RESEARCH & PUBLICATIONS

Published

- **Edge-Native Semantic Firewall for Autonomous LLM Agents: A Structured Chain-of-Thought Verification Framework.** S. Poudel, R. Pandey, A. Pandey. ICICSET 2026, vol. 3(1), pp. 228–235, ISSN 3102-0682, published 2 October 2026. DOI 10.65091/icicset.v3i1.75.
  A 3.8B-parameter model (Phi-3-mini, 4-bit) on one consumer laptop inside a 4.2 GiB VRAM budget, 600 policy scenarios per condition, no cloud inference. The result contradicted the hypothesis: JSON-constrained output without a reasoning field was the least safe evaluator (46.2% unsafe accepts against 17.2% unconstrained), while the structured chain-of-thought arm cut false accepts of irreversible hard-denial commands from 71 to 6 at 66.3% decision accuracy. The paper reports its failures too: 6 of 208 hard denials still approved, and roughly one verdict in ten flips between identical runs.

Presented

- **Evaluating Google's Open Knowledge Format (OKF v0.1) for Multi-Agent Threat Intelligence: A Proof-of-Concept in Digital Forensics.** IC-AICSE 2026, 7 October 2026; Abstract Book p. 32.
- **Detection and Mitigation in IoT Ecosystems: An Empirical Study of Physical-Layer Surveillance and Stateful CSI Obfuscation**, presented as *Evaluating Wi-Fi Sensing Attack Vectors: Covert Threat Detection and Mitigation in IoT Ecosystems*. IC-AICSE 2026, 7 October 2026; Abstract Book p. 33. One paper, two official titles.

Accepted

- **LLM Agent Firewall: Real-Time Detection and Neutralization of Prompt Injection in Multi-Agent Systems.** Paper 4005, oral presentation, 2nd IEEE International Conference on Cybersecurity and AI-Based Systems (Cyber-AI 2026), Bucharest, Romania.
- **A Hybrid Causal-Generative Multi-Agent Framework for Secure Autonomous Mechatronics: Mitigating Real-Time Prompt Injections in Edge-Deployed Disaster Recovery Networks.** Paper 1571313313, with A. Pandey. 4th IEEE International Conference on Artificial Intelligence and Mechatronics Systems (AIMS 2026); presented virtually 23–24 July 2026.
- **PREBAS: Preemptive Bandwidth Scaling for WebRTC in LEO Satellite Networks Using Lightweight Neural Prediction.** 2026 IEEE RTC, Chicago, USA.
- **Designing Real-Time Verification Frameworks for Autonomous Systems.** Accepted by an international journal; acceptance notification received, details on request.

Conference papers and preprints

- **Project Swayam — The Unbreakable Municipality.** Municipal AI Governance Conference 2026, Budhanilkantha Municipality: a fully offline sovereign e-governance stack, with a deterministic gatekeeper in front of a quantized local model.
- **EmbodiedOS: Offline-First Robotic OS with RAG Memory**; **Direct-to-Device LEO Satellite Communication** (Space Con 2026 poster); **Nepal as a Data Center Hub of South Asia** (research paper, 2026).

SOFTWARE & AI PROJECTS

Software engineering

- **Mero Bazaar** — Nepali multi-category marketplace (Next.js, NestJS, PostgreSQL): 52 pre-publication vulnerabilities remediated, with a full post-remediation security report.
- **TradieMate Australia** — Flutter services marketplace with customer and KYC-gated tradie partner apps.
- **AgriSmart** — smart-agriculture platform for Nepal: React, Express, PostgreSQL/Supabase, Khalti payments.

- **TDD/BDD Product Account Service** — RESTful CRUD microservice with pytest unit tests, behave acceptance tests, Dockerfile and CI.
- Also: NEC institutional portal (Next.js, role-based access); enterprise e-commerce (MERN, Redux, Jest, Cypress); Dhukuti Pay offline wallet; NetGuardian and SwiftShare network tooling.

AI engineering

- **Edge-Native Semantic Firewall** — the paper's 600-scenario corpus, raw model outputs for every condition, and a reproducibility checker that can fail; the numbers on this CV come from those artifacts.
- **beyond-attention** — a selective state-space model (Mamba/S6) implemented from scratch in NumPy, published with the results that do not flatter it: a scalar register still ties the agent on the arithmetic tasks, and the model is weaker past its training length.
- **GhostSignal** — disaster life-detection over Wi-Fi Channel State Information (ESP32, mesh networking, penetration-tested): chest movement through rubble, no camera and no wearable.
- **VaultChat** — encrypted peer-to-peer messaging hidden inside a working scientific calculator (Flutter, E2E encryption, steganography).
- **quarantine** — an offline clean room for untrusted model artifacts: contained execution, a judging agent team, verified repair and signed receipts.
- Also: Arth-Sathi and Smart NEPSE (LSTM sentiment engine that re-ranks news sources by historical accuracy); android-emulator-detection (two network-free detection techniques).

EDUCATION

Bachelor in Computer Engineering — Nepal Engineering College (NEC)

Bhaktapur, Nepal · *final year (8th semester) · undergraduate researcher, Department of Computer Science and Engineering*

Coursework: machine learning, computer architecture, operating systems, networks, cryptography and network security, algorithms.

High School — Science (Physics, Mathematics) — St. Xavier's School, Jawalakhel

Kathmandu, Nepal *2020 – 2022*

CERTIFICATIONS

- **IBM AI Engineering Professional Certificate** — IBM, October 2025. Deep learning with Keras/TensorFlow and PyTorch, generative AI and LLMs, transformer fine-tuning, RAG agents with LangChain.
- **IBM DevOps and Software Engineering Professional Certificate** — IBM, March 2026. Agile, containers and Kubernetes, microservices, CI/CD, application security, monitoring and observability.
- **Google Cybersecurity Professional Certificate** — Google, April 2025. Networks and network security, Linux and SQL tooling, threat and vulnerability analysis, detection and response, security automation in Python.
- **Google UX Design Professional Certificate** — Google, December 2025. User research, wireframing, high-fidelity prototyping in Figma, responsive interface design.
- **Specializations:** Deep Learning (DeepLearning.AI), Machine Learning (Stanford University), Flutter and Dart Complete App Development (Packt). Plus 20+ further certificates from Meta, Michigan, Arizona State, Scrimba and Fractal Analytics — full list on request.

AWARDS, LEADERSHIP & SERVICE

- **Hult Prize** — 1st Runner-Up, 2024 and 2025.
- **Aspire Leaders Program** — Global Finalist (2025): one of roughly 10,000 finalists selected from 54,000+ applicants; leadership training co-created by Harvard Business School faculty.
- **Bagmati Province Hackathon 2026** — Runner-Up.
- **NEC IT Club** — Joint Secretary (2024–2025): logistics, administration and student engagement for technical events and hackathons.
- NEC Ingegium Hackathon — volunteer organiser and competitor; Pulchowk Hardware Competition — competitor.

References available on request, including a signed experience letter from Atmos SoftTech Pvt. Ltd. (Md. Samsad Ali, CEO). Security claims name a public link or say why one cannot be checked.